MITRE ATLAS | AML.CS0027 - Organization Confusion on Hugging Face

Entry Information

ID:
AML.CS0027

Type:
Case-Study

Name:
Organization Confusion on Hugging Face

URL:
https://atlas.mitre.org/studies/AML.CS0027/

Incident Date:
2023-08-23

Target:
Hugging Face users

Actor:
threlfall_hax

Description

[threlfall_hax](https://5stars217.github.io/), a security researcher, created organization accounts on Hugging Face, a public model repository, that impersonated real organizations. These false Hugging Face organization accounts looked legitimate so individuals from the impersonated organizations requested to join, believing the accounts to be an official site for employees to share models. This gave the researcher full access to any AI models uploaded by the employees, including the ability to replace models with malicious versions. The researcher demonstrated that they could embed malware into an AI model that provided them access to the victim organization's environment. From there, threat actors could execute a range of damaging attacks such as intellectual property theft or poisoning other AI models within the victim's environment.

Attack Procedure:
[AML.T0021] Establish Accounts: The researcher registered an unverified "organization" account on Hugging Face that squats on the namespace of a targeted company.
[AML.T0073] Impersonation: Employees of the targeted company found and joined the fake Hugging Face organization. Since the organization account name is matches or appears to match the real organization, the employees were fooled into believing the account was official.
[AML.T0044] Full AI Model Access: The employees made use of the Hugging Face organizaion and uploaded private models. As owner of the Hugging Face account, the researcher has full read and write access to all of these uploaded models.
[AML.T0048.004] AI Intellectual Property Theft: With full access to the model, an adversary could steal valuable intellectual property in the form of AI models.
[AML.T0018.002] Embed Malware: The researcher embedded [Sliver](https://github.com/BishopFox/sliver), an open source C2 server, into the target model. They added a `Lambda` layer to the model, which allows for arbitrary code to be run, and used an `exec()` call to execute the Sliver payload.
[AML.T0058] Publish Poisoned Models: The researcher re-uploaded the manipulated model to the Hugging Face repository.

[AML.T0010.003] Model: The victim's AI model supply chain is now compromised. Users of the model repository will receive the adversary's model with embedded malware.
[AML.T0011.000] Unsafe AI Artifacts: When any future user loads the model, the model automatically executes the adversary's payload.
[AML.T0074] Masquerading: The researcher named the Sliver process `training.bin` to disguise it as a legitimate model training process. Furthermore, the model still operates as normal, making it less likely a user will notice something is wrong.
[AML.T0072] Reverse Shell: The Sliver implant grants the researcher a command and control channel so they can explore the victim's environment and continue the attack.
[AML.T0055] Unsecured Credentials: The researcher checked environment variables and searched Jupyter notebooks for API keys and other secrets.
[AML.T0025] Exfiltration via Cyber Means: Discovered credentials could be exfiltrated via the Sliver implant.
[AML.T0007] Discover AI Artifacts: The researcher could have searched for AI models in the victim organization's environment.
[AML.T0016.000] Adversarial AI Attack Implementations: The researcher obtained [EasyEdit](https://github.com/zjunlp/EasyEdit), an open-source knowledge editing tool for large language models.
[AML.T0018.000] Poison AI Model: The researcher demonstrated that EasyEdit could be used to poison a `Llama-2-7-b` with false facts.
[AML.T0048] External Harms: If the company's models were manipulated to produce false information, a variety of harms including financial and reputational could occur.

References

- Model Confusion - Weaponizing ML models for red teams and bounty hunters — https://5stars217.github.io/2023-08-08-red-teaming-with-ml-models/#unexpected-benefits---organization-confusion